

BiteFixes Enterprise Architecture Manual

Volume 10

Identity & Access Management (IAM)

Document ID: BFA-010

Version: 1.0

Status: Draft

Language: English

Architecture Level: Enterprise

Table of Contents

1. Introduction
2. IAM Philosophy
3. Identity Model
4. Authentication
5. Authorization
6. Multi-Tenant Security
7. User Types
8. Roles

9. Permissions

10. Groups

11. Teams

12. Sessions

13. MFA

14. API Security

15. Delegation

16. Audit

17. Identity Lifecycle

18. Security Policies

19. Future Evolution

Chapter 1

Introduction

The Identity & Access Management (IAM) subsystem is responsible for managing identities, authentication, authorization, and access control across the entire BiteFixes platform.

Every action performed within the platform must be associated with a verified identity.

Chapter 2

IAM Philosophy

Authentication answers:

Who are you?

Authorization answers:

What are you allowed to do?

Audit answers:

What did you do?

Identity answers:

Who owns this action?

These concerns remain independent.

Chapter 3

Identity Model

Every identity belongs to exactly one identity type.

Identity

└─ Platform Administrator

└─ Company Administrator

└─ Manager

└─ Technician

└─ Sales Representative

└─ Customer

└─ AI Service

└─ Integration Service

Each identity has a globally unique identifier (UUID).

Chapter 4

Authentication

Supported authentication mechanisms include:

- Username and Password
- Email and Password
- Phone Number and OTP
- OAuth 2.0
- OpenID Connect
- Single Sign-On (SSO)
- Multi-Factor Authentication (MFA)
- API Keys (machine-to-machine)
- JWT Access Tokens
- Refresh Tokens

Passwords are stored using strong adaptive hashing algorithms.

Chapter 5

Authorization

Authorization is enforced through multiple layers.

User

↓

Role

↓

Permissions

↓

Policies

↓

Business Rules

↓

Allowed Action

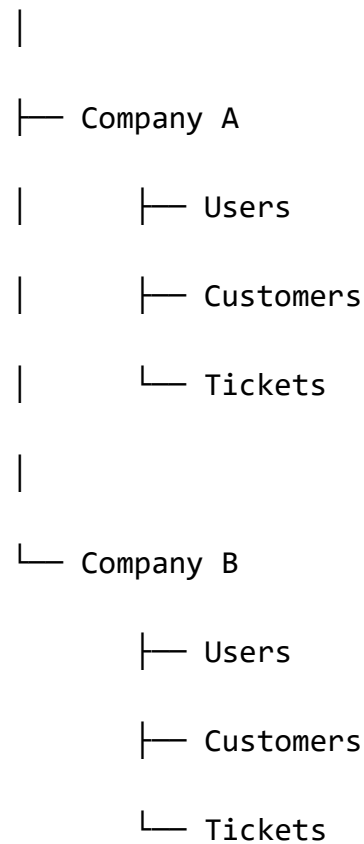
No permission check bypasses the Policy Engine.

Chapter 6

Multi-Tenant Security

Every authenticated identity belongs to exactly one tenant (company), except platform administrators.

Platform



Cross-tenant access is denied by default.

Chapter 7

User Types

The platform distinguishes between internal and external identities.

Internal

- Administrator
- Manager
- Technician
- Sales
- Finance
- Inventory

External

- Customer
- Supplier
- Partner
- Integration

System

- Bitey AI
- Scheduler
- Notification Service
- Event Processor

Chapter 8

Roles

Roles define business responsibilities.

Examples:

PlatformAdmin

CompanyAdmin

ServiceManager

Technician

SalesAgent

InventoryManager

Customer

Guest

Roles do not directly contain business logic.

Chapter 9

Permissions

Permissions represent individual capabilities.

Examples:

customer.read

customer.create

customer.update

customer.delete

ticket.create

ticket.close

ticket.assign

inventory.read

inventory.update

knowledge.publish

Permissions are atomic and reusable.

Chapter 10

Groups

Groups organize users.

Examples:

Technical Support

Sales

Accounting

Administration

Remote Support

Field Service

Permissions can be assigned to groups.

Chapter 11

Teams

Teams represent operational units.

Example:

North Region Team

Server Specialists

Mobile Repair Team

Networking Team

A user may belong to multiple teams.

Chapter 12

Sessions

Every authenticated session includes:

Session ID

User ID

Company ID

Device

IP Address

Country

Browser

Login Time

Expiration

Last Activity

Sessions are revocable.

Chapter 13

Multi-Factor Authentication

Supported second factors:

- Authenticator Apps
- SMS OTP
- Email OTP
- Security Keys (WebAuthn)
- Push Notifications

MFA requirements are configurable by company policy.

Chapter 14

API Security

API access supports:

- OAuth 2.0
- JWT
- API Keys
- Signed Webhooks

Each API token has:

Scope

Expiration

Issuer

Permissions

Allowed Origins

Tokens are revocable.

Chapter 15

Delegation

Users may temporarily delegate responsibilities.

Example:

Manager



Delegates



Technician Approval



Valid Until Friday

Delegation has explicit expiration and audit tracking.

Chapter 16

Audit

Every security-relevant action is recorded.

Examples:

- Login
- Logout
- Failed Login
- Password Change
- Permission Change
- Role Assignment
- MFA Enrollment
- API Key Creation
- Session Revocation

Audit records are immutable.

Chapter 17

Identity Lifecycle

Each identity follows a controlled lifecycle.

Invited

↓

Registered

↓

Verified

↓

Active

↓

Suspended

↓

Archived

Deletion is not permitted; identities are archived.

Chapter 18

Security Policies

Security behavior is governed through configurable policies.

Examples:

- Password complexity.
- Maximum failed login attempts.
- Session timeout.
- MFA enforcement.
- Device trust.
- IP restrictions.
- Country restrictions.
- API rate limits.

These policies are evaluated by the Policy Engine.

Chapter 19

Enterprise Vision

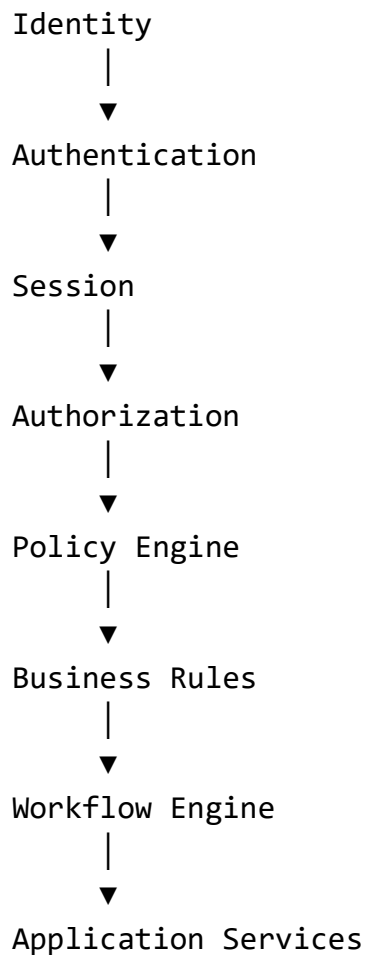
The IAM subsystem is the security foundation of BiteFixes.

Its design supports:

- Small repair shops with a few employees.
- Medium-sized service companies.
- Multi-branch organizations.
- Large enterprises with thousands of users.
- Future federation with external identity providers.

The goal is to keep authentication, authorization, identity management, and auditing independent from business logic while maintaining a consistent security model across the platform.

Canonical IAM Architecture



This layered approach ensures that security decisions are made before business operations are executed.